

张玉峰：企业级 AI Agent 安全风险与整体安全框架

演讲者：张玉峰；活动：2026 腾讯云 AI 产业应用大会 AI Agent 安全专场

2026-06-06



视频作者/频道：指尖安全 / 腾讯云

发布日期：2026-06-05

视频时长：23 分 54 秒（本讲片段 01:09:16-01:33:10）

视频链接：<https://www.bilibili.com/video/BV1xz7C67E2t/>

目录

金字塔结构摘要	2
1 总判断：企业级 Agent 安全对象从应用扩展为行动主体	3
1.1 本章小结	5
2 优先级判断：部署位置和数据敏感度先决定管控强度	5
2.1 本章小结	6
3 攻击判断：真实风险来自内容、工具、授权串成的行动链	7
3.1 本章小结	9
4 框架判断：五域安全能力必须联动成闭环	9
4.1 本章小结	10
5 落地判断：十二项实践要围绕主体、路径、工具、数据和审批分组	11
5.1 本章小结	13
6 结论：把 Agent 当作可行动的软件员工治理	14

金字塔结构摘要

总答案

企业级 AI Agent 安全框架的核心结论是：把 Agent 当作可行动、可授权、可审计的软件员工来治理。它的风险来自身份、权限、工具、数据和运行时行动链的耦合，治理顺序应从场景定级开始，再建立身份、网络、运行时、输入输出和数据五域联动，最后用最小代理能力、网关、沙箱、凭据管理和高危审批落地。

本文按一条主线展开：

1. **先回答为什么风险升级。** Agent 从个人助手进入企业生产场景后，开始持续运行、调用工具、处理敏感数据，安全对象从“应用”扩展为“行动主体”。
2. **再回答先管哪里。** 部署位置和数据敏感度决定风险等级，安全投入应按公有云、私有化、本地、私有数据和非私有数据的组合排序。
3. **然后回答攻击怎么发生。** Copilot 案例说明攻击链会穿过邮件、检索、提示词、授权、令牌、数据收集和分发路径。
4. **最后回答框架如何落地。** 五域框架给出治理面，十二项最佳实践给出可执行控制点。

阅读假设与边界

本文是一份讲座学习笔记，目标是帮助读者理解企业级 Agent 安全框架的结构。内容以字幕、关键帧和现场讲述为依据，重点保留讲者的风险判断、框架划分和落地建议；不构成产品采购评测、漏洞复现报告或合规法律意见。

1 总判断：企业级 Agent 安全对象从应用扩展为行动主体

本节结论

风险升级的根因是 Agent 从短问答助手变成企业数字员工。安全体系需要同时识别它是谁、限制它能做什么、审计它实际做了什么。

张玉峰 1 的分享从一个企业落地问题切入：同样叫 Agent，个人助手和企业级数字员工承担的安全责任完全不同。个人助手通常围绕用户终端、短时任务和低权限调用运行；企业级 Agent 会被放进生产环境、云端工作流、研发系统、办公系统和数据系统里，逐步拥有持续运行、调用工具、访问 API、处理敏感数据的能力。



图 1: 演讲题目页：企业级 AI Agent 安全风险及整体安全框架解析¹

讲者把企业级 Agent 的挑战压缩为四个问题：

- **身份与权限边界扩张。**传统安全管控面向“人、账号、设备、应用”，企业级 Agent 需要被纳入同一套身份治理。直观类比是门禁卡：员工有工牌，Agent 也需要可登记、可授权、可撤销、可审计的“工牌”。
- **攻击从特征转向自然语言。**过去很多攻击依赖样本特征、恶意文件、域名、行为序列；Agent 场景里，一段自然语言指令就可能诱导模型总结邮件、调用工具、读取数据、生成外链。
- **自主性带来行为不确定性。**讲者提到 Plan、ReAct 一类执行模式。Agent 会把目标拆成步骤、选择工具、重试路径。安全风险从一次输入输出扩展到一串行动链。
- **敏感数据与工具调用形成新外泄路径。**Agent 可通过 MCP、Skill、API、插件访问后端业务系统。数据泄露路径因此包含模型输入、模型输出、工具参数、工具返回值、日志、缓存、临时文件和网络出口。

¹视频画面时间区间：01:10:45–01:10:55。



图 2: 企业级 Agent 大规模落地带来的四类挑战²

核心判断

企业级 Agent 的本质接近“能替用户行动的软件主体”。安全体系需要同时管住三件事：它是谁、它能做什么、它正在怎么做。

几个基础概念

Agent 指能根据目标规划步骤并调用工具的软件主体。**MCP** 可理解为 Agent 访问外部工具和数据源的连接协议。**Skill** 类似可安装能力包，可能封装脚本、API 调用或业务动作。**运行时安全** 关注 Agent 执行过程中的真实动作，类似现场值班人员盯住生产线，而非只看开工申请。

用一个解释性风险模型表达，企业级 Agent 的风险同时由误用概率、业务影响和暴露面决定：

$$R_{\text{agent}} \propto P_{\text{misuse}} \times I_{\text{business}} \times E_{\text{exposure}}$$

- R_{agent} ：Agent 风险水平。
- P_{misuse} ：被误用、诱导、劫持或越权的概率。
- I_{business} ：一旦失控对业务、数据、合规和声誉造成的影响。
- E_{exposure} ：Agent 暴露到外网、第三方模型、内部系统、敏感数据和高危工具的程度。

这个模型的价值在于帮助读者排序安全优先级。一个只回答公开营销资料的客服 Agent，与一个能访问代码仓库、内部工单、生产 API 的研发 Agent，在误用概率、业务影响和暴露面上都会出现不同风险量级。

²视频画面时间区间：01:13:44–01:13:55。

1.1 本章小结

本讲的起点是企业级 Agent 的角色变化，而非某个单点漏洞。Agent 一旦从“问答助手”进入“数字员工”，安全对象就从文本生成扩展到身份、权限、数据、工具、网络、日志和责任边界。后续所有框架都围绕这个变化展开。

2 优先级判断：部署位置和数据敏感度先决定管控强度

本节结论

企业级 Agent 安全不能从产品清单起步。合理入口是先确认 Agent、模型、数据和工具分别处在哪个边界内，再按敏感度和外部暴露面确定安全能力优先级。

讲者强调“因地制宜”。企业在讨论安全框架前，需要先回答两个轴向问题：Agent 和模型部署在哪里，处理的数据敏感到什么程度。



图 3: 按部署环境与数据敏感度划分企业级 Agent 安全管控等级³

矩阵横轴可理解为数据从私有到非私有，纵轴可理解为部署从私有环境到公有 SaaS 环境。四个象限代表不同安全压力：

- 公网 SaaS Agent + 公网模型 + 非私有数据。典型场景是市场、营销、客服、问答。重点风险在 Prompt 内容安全、注入、越狱、外部模型安全和供应链安全。
- 公网 SaaS Agent + 私有模型或私有数据。典型场景是研发 Coding Agent、企业云端长期任务 Agent。重点风险转向核心数据泄露、访问内网凭据、推理过程隔离、模型与数据端到端保护。

³视频画面时间区间：01:16:44–01:16:56。

- **全私有化 Agent + 模型 + 私有数据**。典型场景是本地研发助手、内网数据分析、私有 IDC 推理。外部暴露较低，管控重点落在 Agent 行为失控、越权、本地数据误删、Prompt 安全防护。
- **全私有化 Agent + 公共或非私有数据**。风险相对集中在行为边界和基本 Prompt 防护，安全投入可以按业务影响排序。



图 4: 不同类别企业级 Agent 对应的典型风险与痛点⁴

未知风险：混合部署最容易被低估

很多企业会把 Agent、模型、数据、工具部署在不同边界内：Agent 在云端，模型在托管平台，数据在内网，工具由第三方提供。这样的混合链路会让责任边界、日志归属、密钥托管、网络出口和事故响应变得复杂。安全评估若只看其中一个组件，会漏掉跨边界风险。

“公有云”“私有云”“本地”这三个词在安全语境里代表不同控制权。公有云更像租用标准化工位，企业享受弹性和托管能力，同时需要接受平台边界；私有云和本地环境更像自建机房，企业拥有更多控制权，也承担更多运维和加固责任。Agent 一旦连到核心系统，控制权和责任边界必须写清楚。

2.1 本章小结

企业级 Agent 安全框架不能从产品清单起步。合理顺序是：先确认部署位置、数据类型、任务连续性和权限范围，再确定安全能力优先级。部署环境越外部化、数据越敏感、任务越长期、工具权限越大，安全控制越需要前置。

⁴视频画面时间区间：01:17:35-01:17:48。

3 攻击判断：真实风险来自内容、工具、授权串成的行动链

本节结论

Agent 攻击的危险点在于链路长。攻击者可以把恶意指令藏在内容里，经检索进入上下文，再借助 Agent 的工具权限和用户信任完成授权、收集和转发。

风险矩阵回答“企业担心什么”；攻击映射回答“攻击者怎么利用”。讲者引用 OWASP GenAI Security Project 面向 Agentic Applications 的 Top 10，将 Agent 攻击面归纳为目标劫持、工具滥用、身份越权、供应链、代码执行、记忆与上下文投毒、Agent 间通信、防线级联失败、人机信任滥用和流氓 Agent 等类型。



图 5: 企业级 Agent 风险映射攻击手段，包含 OWASP Agentic Applications Top 10⁵

这些类型可以按三层理解：

- **目标层攻击**。攻击者让 Agent 偏离原始任务，例如目标劫持、间接提示词注入、记忆投毒。
- **工具层攻击**。攻击者利用 Agent 调用工具的能力，例如工具滥用、供应链投毒、非预期代码执行。
- **信任层攻击**。攻击者利用人对 Agent 输出的信任，例如让 Agent 代发钓鱼链接、触发授权、请求用户确认敏感操作。

讲者随后用 Microsoft 365 Copilot 高危漏洞案例说明攻击链。该案例的关键点是：恶意指令被藏进邮件，Agent 在总结邮件时读取隐藏指令，输出被劫持，用户被引导到授权或钓鱼流程，攻击者获得令牌后收集并转发邮件、Teams 等数据。

⁵ 视频画面时间区间：01:18:55–01:19:10。

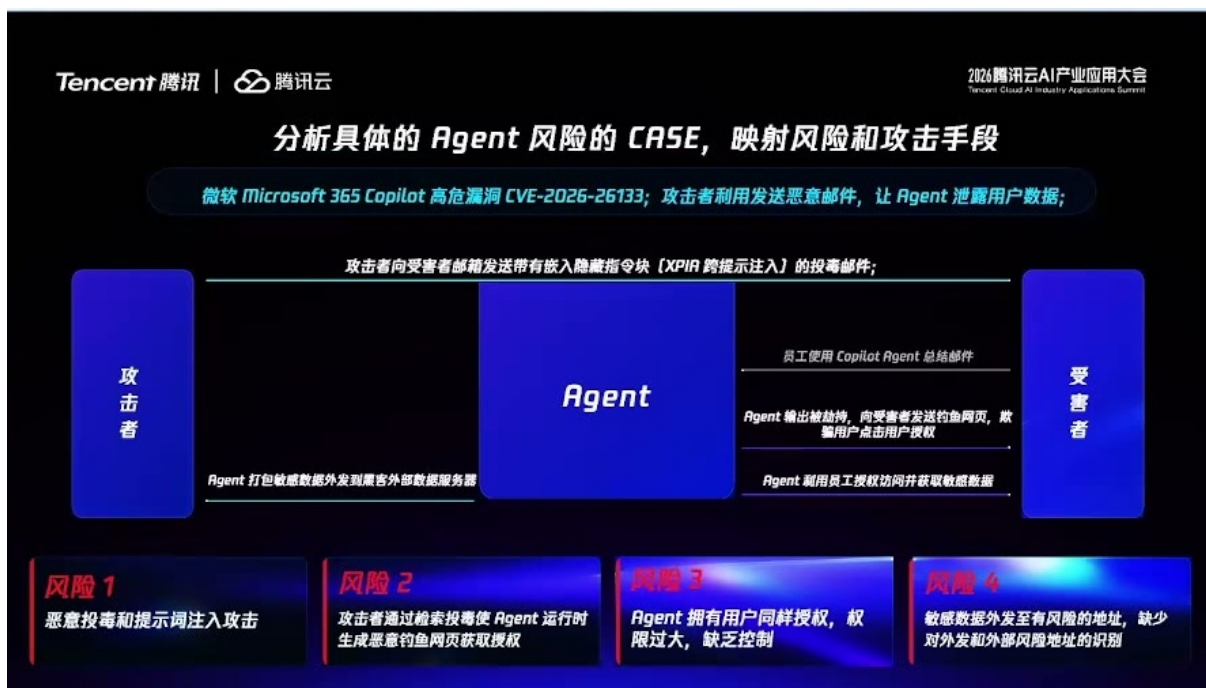


图 6: Microsoft 365 Copilot 案例链路与四类风险：投毒、检索、授权、外发⁶

这个案例值得拆成一条行动链：

1. 攻击者向受害者邮箱投递带有隐藏指令块的邮件。
2. Copilot 类 Agent 对邮件进行总结或检索增强生成，恶意指令进入上下文。
3. Agent 输出被劫持，生成钓鱼内容或诱导授权动作。
4. 用户点击并完成授权后，攻击者获得令牌。
5. Agent 或攻击链收集邮件、协作消息等数据。
6. 数据被打包并外发到攻击者控制的服务器。

案例中的四个风险点

第一是恶意投毒与提示词注入；第二是检索投毒让 Agent 在运行时读到有害上下文；第三是 Agent 继承员工身份后放大授权后果；第四是敏感数据可通过多条路径外发，传统文件外发和网络外发控制覆盖不完整。

间接提示词注入与检索投毒

间接提示词注入指恶意指令藏在网页、邮件、文档、代码注释等外部内容里，用户本人没有直接输入攻击语句，Agent 读取材料后被诱导执行。**检索投毒**指攻击者污染知识库、搜索结果、邮件库、文档库或记忆库，让 Agent 在检索阶段拿到有害上下文。二者的危险在于攻击语句常常出现在“资料”里，普通输入过滤很难覆盖。

从防守角度看，案例暴露了一个经常被忽略的问题：员工身份可以通过 IDP、RBAC、会话令牌等机制管控；Agent 代理员工后，安全系统若只看到用户 Session ID，溯源人员很难判断请求来

⁶视频画面时间区间：01:22:42-01:22:58。

自人类操作还是 Agent 自动操作。缺少 Agent 身份、运行时审计和工具调用审计时，事故调查会变成猜测。

3.1 本章小结

Agent 攻击的核心变化在于行动链变长。攻击者不一定直接突破系统边界，也可以通过内容、检索、工具、授权和信任关系逐步让 Agent 做出危险动作。防御需要覆盖输入、检索、工具调用、身份继承、输出、网络出口和日志审计。

4 框架判断：五域安全能力必须联动成闭环

本节结论

五域框架的价值在联动。身份给出主体，网络收束连接，运行时观察动作，输入输出控制上下文，数据安全限制机密信息流向；缺少任一域都会留下跨边界风险。

讲者在案例之后提出框架设计方法：先想清楚 Agent 在业务侧做什么，再参考身份安全、网络传输、运行时、数据和模型安全等框架，随后做能力选型、优先级排序和责任边界约束。



图 7：腾讯云面向企业级 Agent 的五域安全框架指南⁷

五个安全域可以这样理解：

- **身份和权限。**为 Agent 注册身份，接入企业 IDP，进行 Agent 授权管理。目标是让每个 Agent 可识别、可授权、可撤销、可审计。
- **网络访问控制。**隔离网络运行环境，通过网络白名单、访问控制和传输加密限制 Agent 的内外连接。

⁷ 视频画面时间区间：01:25:41–01:25:54。

- **运行时安全**。检测 Agent 运行时漏洞，隔离运行环境，监控 Tool Call、Skill 执行和实时行为审计。运行时相当于“任务现场”的控制层。
- **模型输入输出**。检测 Prompt 内容合规、注入、越狱和输出风险。输入输出控制是必要入口，覆盖范围仍需与运行时和数据层联动。
- **数据安全**。包含机密模型推理、敏感凭据管理、敏感数据识别和数据外发控制。

讲者提到一个关键原则：Agent 的安全应遵循“赋予 Agent 身份、控制 Agent 获得的授权、叠加 Least Agency 与运行时安全”。这句话适合拆成四个联动控制点：

控制点	作用
Agent 独立身份	区分 Agent、人类用户和普通应用，让请求可归因、可撤销、可审计。
最小代理能力	只授予完成当前任务所需动作和资源，是最小权限原则在 Agent 场景中的扩展。
运行时防护	通过沙箱、命令审计、Tool Call 检测、Skill 安全检测和高危操作拦截观察真实动作。
数据边界	通过数据分类、密钥托管、机密推理、输出过滤和外发路径控制限制机密信息流向。

表 1: 企业级 Agent 安全治理的四个联动控制点

不要把框架误解为五个孤岛

五个安全域需要打通策略、日志和责任归属。身份域若不给运行时审计提供 Agent ID，日志会失去主体；数据域若不知道工具调用上下文，外发策略会误判；网络域若没有业务角色信息，白名单会变成粗粒度放行。

一个实践性更强的控制闭环可以表示为：

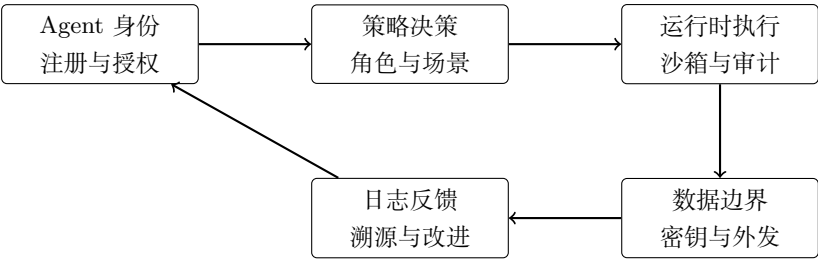


图 8: 企业级 Agent 安全控制闭环：主体、策略、执行、数据和反馈需要相互连接

4.1 本章小结

整体安全框架的关键在联动。身份决定谁在行动，网络决定能连到哪里，运行时决定实际做了什么，输入输出决定模型上下文是否安全，数据安全决定机密信息能否被拿走。企业若只采购一个单点产品，覆盖面会明显不足。

5 落地判断：十二项实践要围绕主体、路径、工具、数据和审批分组

本节结论

最佳实践的落地顺序是先限定主体和连接路径，再治理 Skill、MCP、凭据和数据访问，最后用运行时审计与人工审批兜住高危动作。

讲者展示了腾讯云可落地的 AI Agent 安全方案。图中包含 Agent 访问入口、桌面级运行、云端运行、Agent 安全中心、IOA、AI Agent 安全网关、模型输入输出检测、机密推理、内部服务调用和用户交互界面。



图 9: 腾讯云提供的 AI Agent 安全方案：运行时、安全中心与安全网关协同⁸

这个方案可以按三条控制线理解：

- **宿主与运行时控制线。**桌面应用、云端 Agent Runtime、Hook、沙箱、Tool Call 防护、权限隔离和日志审计构成执行侧控制。
- **网关控制线。**AI Agent 安全网关负责模型输入输出检测、MCP 敏感访问管理、机密数据识别、自动加密托管和 Agent 授权管理。
- **数据与服务控制线。**Agent 调用企业内部服务、云原生 API、数据库和大数据 MCP 时，需要通过分类授权、密钥托管和访问审计降低横向移动与数据泄露风险。

⁸ 视频画面时间区间：01:27:20–01:27:50。



图 10: 腾讯云安全对企业级 Agent 落地安全最佳实践的思考：五大类十二项⁹

十二项最佳实践的父结论是：企业需要先定义 Agent 主体，再收束访问路径。随后治理 Skill/MCP、数据和凭据，最后用运行时审批处理高危动作。按控制对象可整理为五组：

1. 身份认证和访问控制：先定义谁在行动。

- 根据业务场景创建不同 Agent 角色。每个角色绑定固定资源访问权限，例如营销、运营、研发等角色拥有不同 API 和数据访问集合。
- 为 Agent 开启企业身份认证。入向和出向都要识别 Agent 身份，避免日志里只看到用户 Session，无法区分人类操作与 Agent 操作。

2. 网络与网关：再收束它能连到哪里。

- 独立 VPC 或沙箱部署 Agent。云端 Agent 可放入 VPC 类隔离环境，本地 Agent 可放入本地沙箱。
- 按需开通内外网访问权限。使用白名单逐步放通必要访问，减少 Agent 自主寻找替代路径造成的外发风险。
- 通过安全网关访问外部大模型和 MCP。网关是统一审计、路由、加密、检测和策略执行的关键位置。

3. Skill 与 MCP 管理：控制它通过哪些能力做事。

- 对 Skill 和 MCP 按鉴权类别分类。关联核心业务或敏感数据的 Skill 需要更严格的身份和权限校验。
- 从可信 Skill 库下载，并对本地 Skill 做安全检测。Skill 类似插件，供应链风险和本地脚本风险都要纳入治理。

⁹ 视频画面时间区间：01:28:41–01:32:48。

4. 数据与凭据：限制它能接触和带走什么。

- 禁止在 Skill 或本地文件中存储明文密钥。密钥应托管在网关、密钥管理服务或受控沙箱中。
- 对访问服务进行分类。普通服务、敏感服务、共享凭据服务和需要动态授权的服务应采用不同访问策略。
- 避免让 Skill 直接访问原始数据。优先封装成可鉴权、可审计、可限流、可回收的 MCP 或 API。

5. 规范与运行时防护：让高危动作可拦截、可确认、可追责。

- 建立安全规范并做数据安全宣贯。规范要覆盖开发者如何编写 Skill、如何处理凭据、如何接入网关、如何记录日志。
- 高危操作增加人工审批。删除、外发、批量访问、权限变更、执行命令等动作应根据风险等级触发确认。

最小代理能力

Least Agency 的直觉类比是“只给临时工一张当天、当前楼层、当前房间可用的门禁卡”。Agent 不应继承用户全部能力，只应获得完成当前任务所需的最小行动集合。

可以把权限设计写成集合关系：

$$\text{Allowed}(a, r, t) \subseteq \text{Need}(r, t) \cap \text{Policy}(r) \cap \text{Context}(t)$$

- a ：某个具体 Agent。
- r ：Agent 的业务角色，例如研发、运营、客服。
- t ：当前任务。
- $\text{Allowed}(a, r, t)$ ：最终授予 Agent 的动作与资源集合。
- $\text{Need}(r, t)$ ：完成任务实际需要的动作集合。
- $\text{Policy}(r)$ ：组织对角色的长期策略约束。
- $\text{Context}(t)$ ：当前上下文约束，例如时间、网络位置、数据分类、审批状态。

这个集合关系的含义很硬：如果某个动作无法同时通过任务需要、角色策略和上下文约束三道门，它就不应进入 Agent 的可执行集合。

5.1 本章小结

落地方案的重点是把安全能力放到 Agent 行动链的关键节点上：入口认证、模型调用、工具调用、运行沙箱、网络出口、数据访问、日志审计和人工审批。十二项最佳实践给出的方向很明确：先定义角色和身份，再控制网络和工具，随后治理数据和运行时。

6 结论：把 Agent 当作可行动的软件员工治理

讲者最后把讨论收束到企业实践：企业级 Agent 的安全建设需要从角色、身份、网络、Skill/MCP、数据和运行时审批逐步落地；高危操作需要人工审批；敏感凭据不能硬编码进 Skill；外部模型、MCP 和内部服务访问要经过安全网关；Agent 的请求需要可审计、可溯源、可追责。

本讲可压缩成五条核心结论：

1. **Agent 是新的行动主体。**它需要独立身份，而非只挂在人类用户 Session 后面。
2. **风险边界从应用扩展到行动链。**输入、检索、计划、工具调用、数据读取、输出和外发都可能成为攻击路径。
3. **部署矩阵决定管控强度。**公有云、私有云、本地、私有数据、非私有数据的组合不同，安全优先级不同。
4. **运行时是企业级 Agent 安全的关键战场。**Prompt 防护只能覆盖一部分风险；真正危险的动作通常发生在工具调用、命令执行、文件读写和网络出口。
5. **责任边界要提前写进治理机制。**谁批准 Agent 上线，谁定义角色权限，谁维护 Skill 库，谁审计日志，谁处理事故，都要明确。

企业容易遗漏的几个问题

第一，日志里没有 Agent ID，事故后难以溯源。第二，Skill 开发者把密钥写进本地文件，投毒后直接泄露。第三，网关只管模型输入输出，工具调用绕过审计。第四，高危动作没有审批，Agent 以效率名义拿到过宽权限。第五，外部 MCP 或插件供应链缺少安全准入。

从架构视角看，企业级 Agent 安全可以用一句话概括：把 Agent 当作可行动、可授权、可审计的软件员工来治理。它需要工牌、岗位职责、办公区域、操作规程、值班监控、审计记录和事故追责。缺其中任何一环，Agent 的效率收益都会伴随不可控风险。

本讲还留给企业一个现实问题：安全建设永远受预算、组织协同和业务速度约束。合理做法是先从高影响场景入手，例如研发、运维、客服、数据分析和办公协同中的长期 Agent；再把身份、网关、运行时、数据分类和审批机制做成可复用平台。这样，企业可以在不阻断创新的前提下，把 Agent 从“能用”推进到“可控地用”。